

# LVChat

## Full Monty Audit Report

0 CRITICAL · 1 HIGH · 1 MEDIUM · 0 LOW

Generated: August 11, 2026 at 06:04 PM

Scope: FULL\_MONTY

Total findings: 2 · Security: 1 · Performance: 0 · UI/UX: 1

## Executive Summary

| Metric                | Value |
|-----------------------|-------|
| Total Findings        | 2     |
| Critical Severity     | 0     |
| High Severity         | 1     |
| Medium Severity       | 1     |
| Low Severity          | 0     |
| ---                   | ---   |
| Security findings     | 1     |
| Performance findings  | 0     |
| UI/UX findings        | 1     |
| ---                   | ---   |
| GPT-OSS-20b findings  | 0     |
| MiniMax/grep findings | 1     |

## Methodology

**Security scan (Step 2.5):** Two-model parallel approach. Model A — GPT-OSS-20b at 192.168.8.147:1234 (Botbox2): static per-file security review using a 6-thread worker pattern. Model B — MiniMax + local grep sweep: regex/heuristic pass over all source files. Vulnerability classes scanned: SQLi, XSS, CSRF, IDOR,

AuthBypass, HardcodedSecret, SessionHardening, FileUpload/PathTraversal, TimingAttack, Cron/TOCTOU, InfoDisclosure, InsecureDeserialization, OpenRedirect, MissingRateLimit, CORS/OriginCheck, HeaderInjection.

**Performance scan (Step 2.6):** Same two-model pattern. Classes scanned: N+1, MissingIndex, UnboundedResultSet, SyncExternalCall, MissingCache, AssetBloat, RenderBlocking, ExcessiveDOM, MemoryHotPath, ResourceLeaks, CronInefficiency, ColdStart, FrontendRuntime, NetworkPayload, ConnectionPool, Concurrency.

**UI/UX scan (Step 2.7):** Same two-model pattern plus Playwright screenshot review where available. Classes scanned: a11y, FormUX, LoadingStates, ErrorUX, InformationArchitecture, VisualConsistency, ResponsiveDesign, i18n, StateFeedback, Discoverability, NativeDialog, DataBinding, DeadUI, ColorContrast, Microcopy, Motion, PrintExport.

**Severity scale:** Critical (direct exploit / unusability) → High (realistic exploit / visible breakage) → Medium (preconditions / tolerable lag) → Low (defense-in-depth / polish).

**Scope rule (CRITICAL):** *install/*, *e2e/*, and *tests/* directories are excluded from live-code audit scope. They are development-only and must never reach production. These folders should be manually deleted before any upload.

# Security Findings

1 finding(s): 0 Critical · 1 High · 0 Medium · 0 Low

| H-02            | HIGH                                                                                                                         | BrokenAccessControl | manual audit of bin/ws-server.php + regression test |
|-----------------|------------------------------------------------------------------------------------------------------------------------------|---------------------|-----------------------------------------------------|
| File : Line     | bin/ws-server.php : 312                                                                                                      |                     |                                                     |
| Vulnerable Code | case 'subscribe': if (!empty(\$msg['channel'])) { \$st['sub'] = ['type' => 'channel', 'target' => (string) \$msg[...         |                     |                                                     |
| Description     | WS-mode realtime authorization gap: the Workerman gateway accepted a subscribe for ANY channel slug or DM username fr        |                     |                                                     |
| Remediation     | (1) Channel subscriptions authorized at subscribe time via AccessService::member(). (2) DM fan-out authorized at broadcast t |                     |                                                     |

# UI/UX Findings

1 finding(s): 0 Critical · 0 High · 1 Medium · 0 Low

|                 |                                                                                                                                  |              |                                                   |
|-----------------|----------------------------------------------------------------------------------------------------------------------------------|--------------|---------------------------------------------------|
| U-02            | MEDIUM                                                                                                                           | NativeDialog | grep sweep across views/ + throwaway Electron e2e |
| File : Line     | views/admin/* + views/user/profile.php : 0                                                                                       |              |                                                   |
| Vulnerable Code | onsubmit="return confirm('...') / var reason = prompt(msg, ") / alert(j.error)                                                   |              |                                                   |
| Description     | Native dialog abuse: 34 window.confirm()/prompt()/alert() call sites across the admin views and the user profile page, while the |              |                                                   |
| Remediation     | Added public/assets/js/dialog.js — a self-contained styled-modal LVCDialog (confirm/prompt/alert, promise-based) plus a data     |              |                                                   |